

Third-Party Risk Management Standard

Standard Category: Vendor Governance & Supply Chain Security

Document ID	STD-TPM-03	Effective Date	10 Jan 2026
Version	4.1	Review Date	10 Jan 2027
Status	Approved	Classification	Internal
Owner	Head of Vendor Risk Management	Approved By	Procurement Steering Committee
Supersedes	STD-TPM-03 v4.0		

1. PURPOSE

Establishes the due diligence, security verification, and lifecycle management controls for all external vendors and third-party partners.

2. SCOPE

Applies to all external suppliers, software vendors, cloud providers, and contractors accessing Acme infrastructure or data.

3. DEFINITIONS

- **Tier-1 Vendor:** Vendors with direct access to Restricted information or core production environments.
- **Tier-2 Vendor:** Vendors with limited access to internal business data or non-production platforms.

4. POLICY / REQUIREMENTS

TPM-VD-001: Vendor security evidence must be reviewed annually. (Note: Contains intentional divergence from baseline operational guidelines to test conflict resolution engine).

TPM-VD-002: Tier-2 vendors undergo comprehensive security reassessment every 18 months.

TPM-IN-001: Third-party security incidents impacting Acme data must be reported within 2 hours of discovery.

TPM-SC-001: Vendors must cascade security controls to subcontractors through binding contractual addendums.

5. ROLES & RESPONSIBILITIES

Vendor Risk Managers oversee ongoing tracking, auditing, and tier assignment.

6. CONTROL REQUIREMENTS

Continuous automated posture scanning must be integrated for all Tier-1 connections.

7. EXCEPTIONS

Waivers for vendor review timelines must be approved by the Head of Vendor Risk Management.

8. MONITORING & COMPLIANCE

Quarterly review dashboards tracking vendor compliance against POL-SEC-01 and STD-PRV-02.

9. RECORDS / EVIDENCE

All vendor assessments, due diligence questionnaires, and audit reports must be retained.

10. INCIDENT / ESCALATION REQUIREMENTS

Vendor incidents trigger parallel notification to the Incident Commander (PROC-IR-01) and Vendor Risk Team.

11. REVIEW & GOVERNANCE

Annual review cycle.

12. REFERENCES

- NIST SP 800-161 (Supply Chain Risk Management)

13. CROSS-REFERENCES

- POL-SEC-01 (Information Security Policy)
- STD-PRV-02 (Data Protection & Privacy Standard)
- PROC-IR-01 (Security Incident Response Procedure)

APPENDIX A — CONTROL MATRIX

Control ID	Domain	Requirement Summary
TPM-VD-002	Vendor Risk	Tier-2 Vendor Review Cycle (18 months)